

Get your solution Enterprise ready: a legal and compliance perspective

Practical Tips & Tricks



Daniel von Büren

Swiss Security Officer

Agenda



Responsibilities



Understand Your Stakeholders



Compliance



Risk Assessment & How To Address Them



Open Exchange

Shared Responsibility Model In The Cloud



Customer management of risk

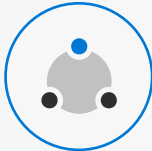
Data classification and data accountability





Shared management of risk

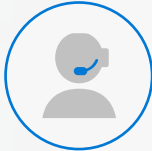
Identity & access management | End point devices



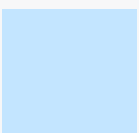
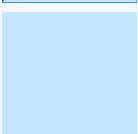
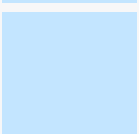
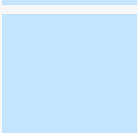
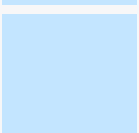
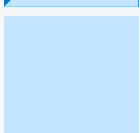
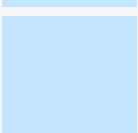
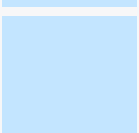


Provider management of risk

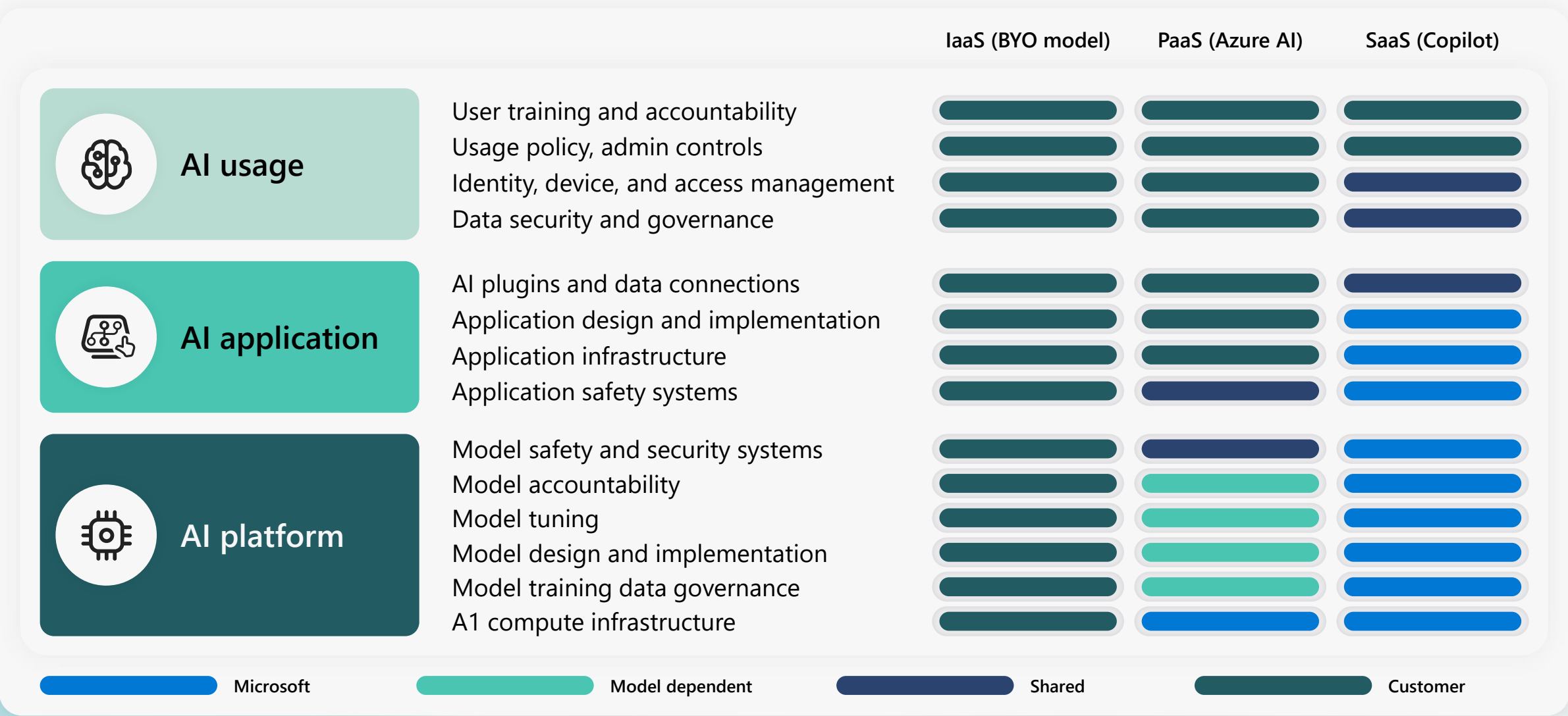
Physical | Networking



 Cloud customer  Cloud provider

Responsibility	On-Prem	IaaS	PaaS	SaaS
Data classification and accountability				
Client & end-point protection				
Identity & access management				
Application level controls				
Network controls				
Host infrastructure				
Physical security				

Shared Responsibility Model For AI





Understand Your “Other” Stakeholders

Chief Information Security Officer (CISO)

Role description

A Chief Information Security Officer (CISO) is responsible for **protecting the company's business, data, and customers from cyber risk while enabling innovation and growth**. Rather than saying "no," the CISO's job is to make risk transparent and help the business make informed decisions.

Potential Questions / Concerns

- What business risk does this introduce or reduce? What is the risk of inaction?
(Data exposure, downtime, regulatory impact, reputational damage)
- Is security built in by design, or added later?
(Identity, access, logging, encryption, secure defaults)
- What happens when—not if—something goes wrong?
(Detection, response, recovery, and business continuity)
- Does this scale safely as the company grows?
(More users, more data, more integrations, more attackers)
- Are we accepting this risk consciously—or by accident?
(Clear ownership, risk acceptance, and accountability)



Picture is generated with the help of AI

Data Protection Officer (DPO)

Role description

A Data Protection Officer (DPO) ensures that **personal data is processed lawfully, transparently, and responsibly, while advising the business on privacy risks and regulatory obligations**. The DPO's role is not to block innovation, but to make sure new products and systems respect individuals' rights and can stand up to regulatory scrutiny.

Potential Questions / Concerns

- What personal data is processed, and is it really needed?
(Purpose limitation, data minimization, lawful basis)
- Is privacy built in by design and by default?
(Access controls, data segregation, retention limits, auditability)
- What are the risks to individuals' rights and freedoms?
(Profiling, monitoring, misuse, unintended secondary use)
- Do we need a Data Protection Impact Assessment (DPIA)?
(New technologies, large-scale processing, sensitive data)
- Can we explain and defend this design to regulators and customers?
(Transparency, documentation, accountability)



Picture is generated with the help of AI



Compliance



Compliance Framework

Contracts

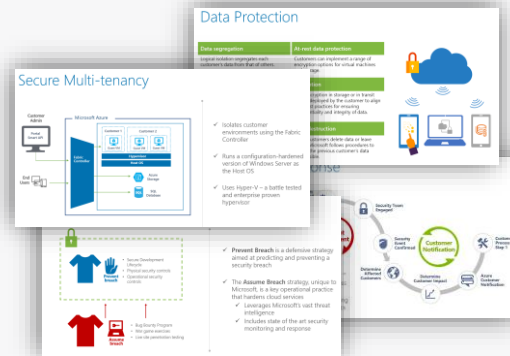
Online Product Terms & Data Protection Addendum (DPA)

General and specific regulations about all relevant topics (e.g. data handling, security,...) between customer and Microsoft.

Implementation

Technical and Organizational Measures (TOM)

TrustCenter and Learn provides all details:



Control-framework

Ensure successful implementation of TOM's

Over 100 global, industry specific or regional certifications:



Reporting

Audit reporting

Regularly independent audits per service. Audit reports would be published on TrustCenter to all customers including all details (full transparency).

Microsoft covers over 100 compliance offerings

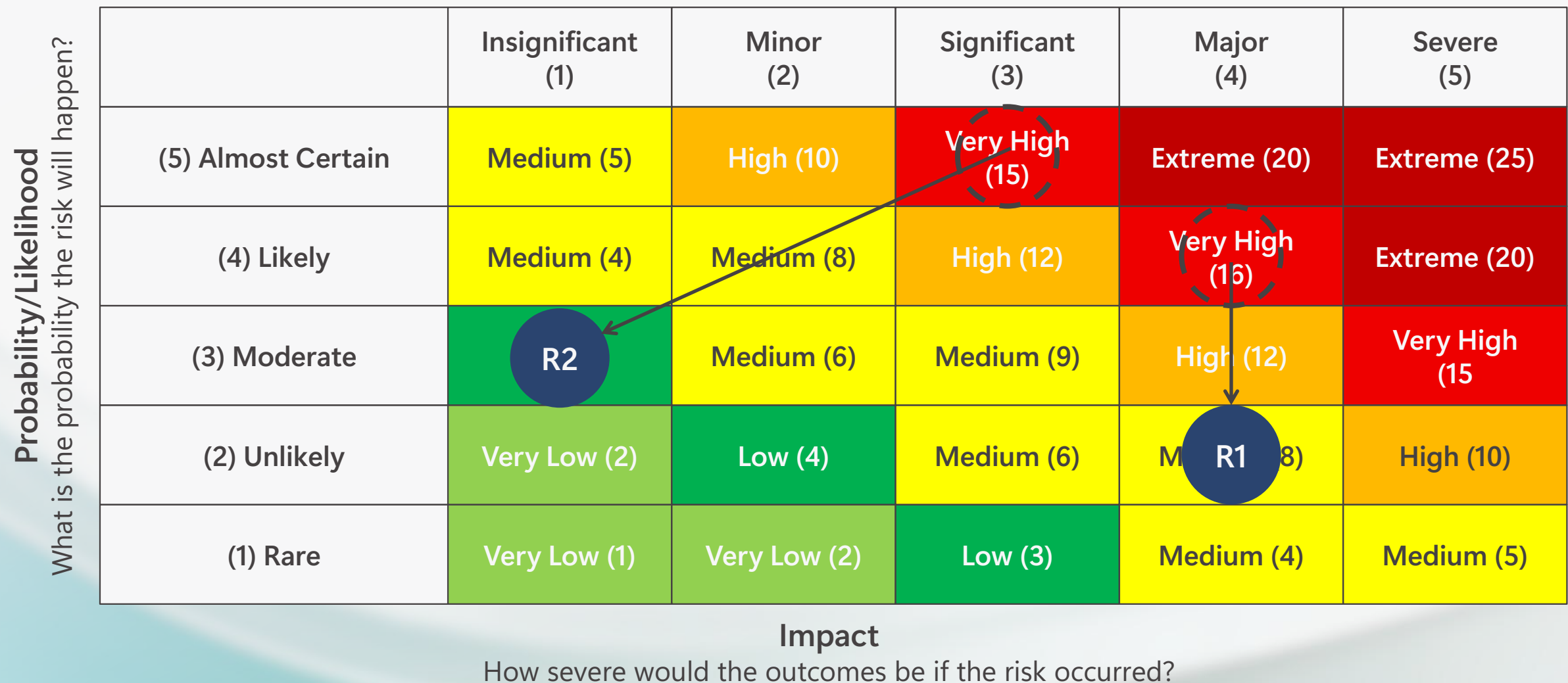
Microsoft has the deepest and most comprehensive compliance coverage in the industry

Global	US Gov	Industry		Regional	
• CIS Benchmark • CSA STAR attestation • CSA STAR certification • CSA STAR self-assessment • ISO 20000-1 • ISO 22301 • ISO 27001 • ISO 27017 • ISO 27018 • ISO 27701 • ISO 9001 • SOC 1 Type 2 • SOC 2 Type 2 • SOC 3 • WCAG 2.0 (ISO 40500)	• CJIS • CNSSI 1253 • DFARS + CMMC • DoD IL2 • DoD IL4 • DoD IL5 • DoD IL6 • DoE 10 CFR Part 810 • EAR • FedRAMP • FIPS 140-2 • IRS 1075 • ITAR • NIST 800-171 • NIST 800-53 • NIST CSF • Section 508 VPATs	Automotive • TISAX (Germany) Education • FERPA (US) Energy • NERC (US) Financial Services • 23 NYCRR 500 (US) • AFM + DNB (Netherlands) • AMF + ACPR (France) • APRA (Australia) • CFTC 1.31 (US) • EBA (EU) • FCA + PRA (UK) • FFIEC (US) • FINMA (Switzerland) • FINRA 4511 (US) • FISC (Japan) • FSA (Denmark) • GLBA (US) • KNF (Poland) • MAS + ABS (Singapore) • NBB + FSMA (Belgium) • OSFI (Canada)	Financial Services (Cont.) • OSPAR (Singapore) • PCI DSS Level 1 • PCI 3DS • RBI + IRDAI (India) • SEC 17a-4 (US) • SEC Regulation SCI (US) • Shared assessments (US) • SOX (US) • TruSight Healthcare and Life Sciences • ASIP HDS (France) • GxP (FDA 21 CFR Part 11) • HIPAA (US) • HITRUST • MARS-E (US) • NEN 7510 (Netherlands) Media and Entertainment • CDSA • DPP (UK) • FACT (UK) • MPA Telecommunications • GSMA	Americas • Argentina PDPA • Canada Privacy Laws • US CCPA Asia Pacific • Australia IRAP Unclassified • China GB 18030:2005 • China DJCP (MLPS) • China TRUCS/CCCPPF • China TCS • India MeitY • Japan CS mark gold • Japan My Number act • Korea K-ISMS • New Zealand ISPS • Singapore MTCS Level 3	Europe and Middle East • EU EN 301 549 • EU ENISA IAF • EU GDPR • EU model clauses • Germany C5 • Germany IT—Grundschutz workbook • Netherlands BIR 2012 • Russia personal data law • Spain ENS High • Spain LOPD • UAE DESC • UK cyber essentials plus • UK G-Cloud • UK PASF

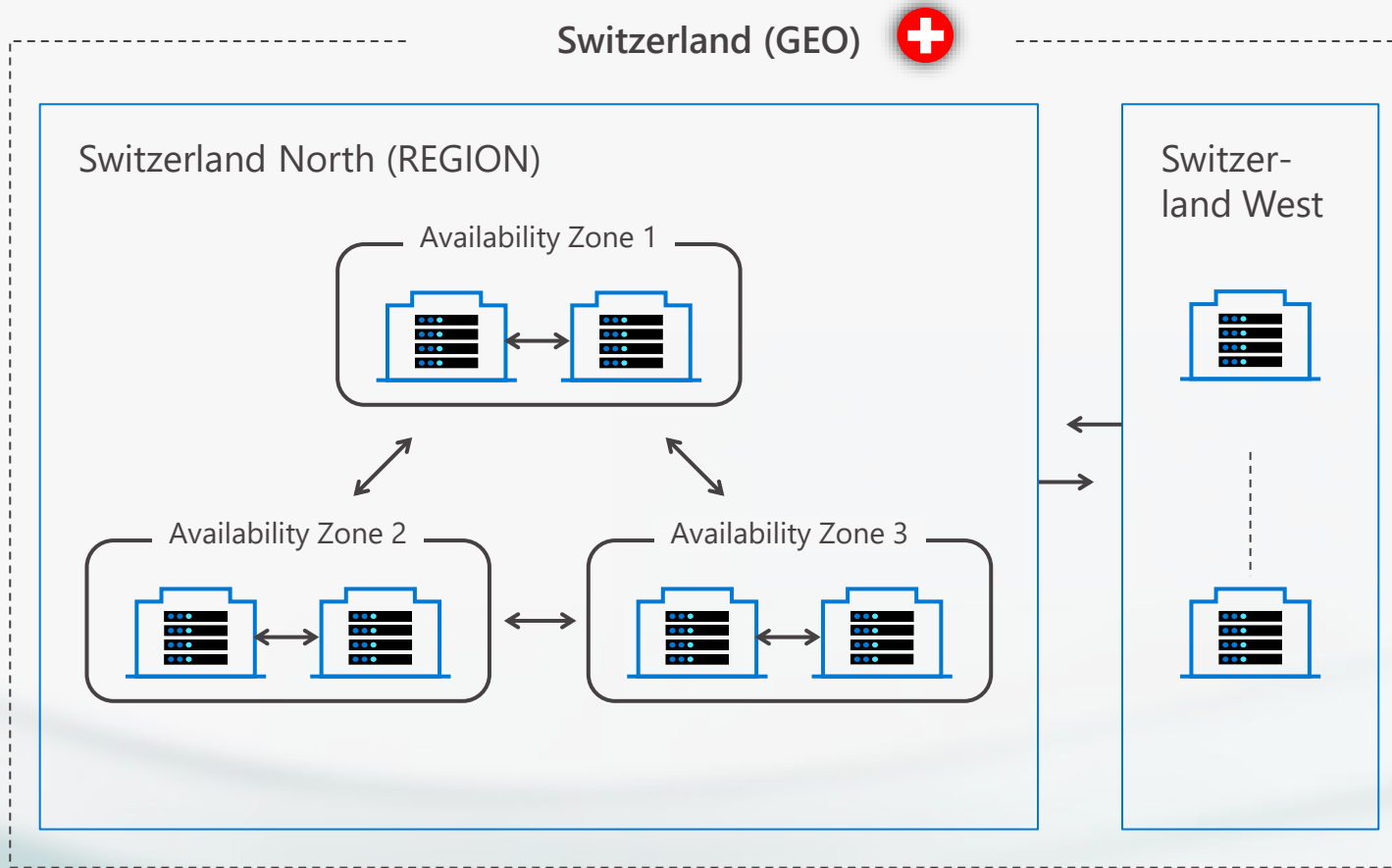


Risk Assessment & How To Address Them

Risk Assessment (Risk-Based Approach)



Data Residency / Business Continuity Management



EU Data Boundary

The European Union Data Boundary (EUDB) enables customers in EU and EFTA countries to **process** and **store** their data **in the EU**.

This includes: customer data and pseudonymized personal data for Microsoft 365, Dynamics 365, Power Platform, and Azure, as well as Professional services data.

(contractually committed)

Promises

- Store and process data in the EU
- Expand datacenters in the EU
- Provide for global security
- Provide in-region support model

Lawful Access (CLOUD Act) I/II

Im Daten-Dschungel: Wie Microsoft mit dem CLOUD Act umgeht

11. Februar 2021



In dieser Ausgabe unserer Reihe „Im Daten-Dschungel“ geht es darum, wie wir mit Anfragen von US-Strafverfolgungsbehörden umgehen, die Zugriff auf Daten fordern, die auf Cloud-Servern von Microsoft, aber außerhalb der USA liegen.

Zentraler Grundsatz unserer Arbeit ist es, die Daten unserer Kund*innen nicht ohne ihr Wissen an Dritte weiterzugeben oder diesen Zugriff darauf zu gewähren. Aber wie verhalten wir uns, wenn uns Behörden auffordern, ihnen personenbezogene Daten unserer Kunden zur Verfügung zu stellen – etwa im Rahmen einer Strafverfolgung?

Tatsächlich ist das eine ziemlich komplexe Frage, die auch nach vielen Jahren intensiver politischer und juristischer Auseinandersetzungen noch immer nicht final geklärt ist. Erst im Juli 2020 hat der Europäische Gerichtshof (EuGH) befunden, dass durch die Zugriffsmöglichkeiten der US-Behörden und -Geheimdienste die Anforderungen an den Datenschutz bei einer Übermittlung personenbezogener Daten an Drittländer wie die USA nicht gewährleistet seien (Schrems II-Urteil).

Mit unseren im November 2020 angekündigten Schutzmaßnahmen „[Defending Your Data](#)“ haben wir unser [grundlegendes Datenschutz-Versprechen](#) ergänzt: Diese beinhalten die vertragliche Verpflichtung, Anfragen von staatlichen Stellen nach Kundendaten anzufechten, sowie eine finanzielle Verpflichtung, um unsere Überzeugung in dieser Sache zu unterstreichen.

Disclosure of Processed Data

Microsoft will not disclose or provide access to any Processed Data except: (1) as Customer directs; (2) as described in this DPA; or (3) as required by law. For purposes of this section, “Processed Data” means: (a) Customer Data; (b) Professional Services Data; (c) Personal Data; and (d) any other data processed by Microsoft in connection with the Products and Services that is Customer’s confidential information under Customer’s agreement. All processing of Processed Data is subject to Microsoft’s obligation of confidentiality under Customer’s agreement.

Microsoft will not disclose or provide access to any Processed Data to law enforcement unless required by law. If law enforcement contacts Microsoft with a demand for Processed Data, Microsoft will attempt to redirect the law enforcement agency to request that data directly from Customer. If compelled to disclose or provide access to any Processed Data to law enforcement, Microsoft will promptly notify Customer and provide a copy of the demand unless legally prohibited from doing so.

Upon receipt of any other third-party request for Processed Data, Microsoft will promptly notify Customer unless prohibited by law. Microsoft will reject the request unless required by law to comply. If the request is valid, Microsoft will attempt to redirect the third party to request the data directly from Customer.

Microsoft will only disclose or provide access to any Processed Data as required by law provided that the laws and practices respect the essence of the fundamental rights and freedoms and do not exceed what is necessary and proportionate in a democratic society and, as applicable, to safeguard one of the objectives listed in Article 23(1) of GDPR.

Microsoft will not provide any third party: (a) direct, indirect, blanket, or unfettered access to Processed Data; (b) platform encryption keys used to secure Processed Data or the ability to break such encryption; or (c) access to Processed Data if Microsoft is aware that the data is to be used for purposes other than those stated in the third party’s request.

In support of the above, Microsoft may provide Customer’s basic contact information to the third party.

Source: [Data Protection Addendum \(DPA\) – chapter “Disclosure of Processed Data”](#)

Lawful Access (CLOUD Act) II/II

Appendix C – Additional Safeguards Addendum

By this Additional Safeguards Addendum to the DPA (this “Addendum”), Microsoft provides additional safeguards to Customer for the processing of personal data, within the scope of the GDPR, by Microsoft on behalf of Customer and additional redress to the data subjects to whom that personal data relates.

This Addendum supplements and is made part of, but is not in variation or modification of, the DPA.

1. **Challenges to Orders.** In the event Microsoft receives an order from any third party for compelled disclosure of any personal data processed under this DPA, Microsoft shall:
 - a. use every reasonable effort to redirect the third party to request data directly from Customer;
 - b. promptly notify Customer, unless prohibited under the law applicable to the requesting third party, and, if prohibited from notifying Customer, use all lawful efforts to obtain the right to waive the prohibition in order to communicate as much information to Customer as soon as possible; and
 - c. use all lawful efforts to challenge the order for disclosure on the basis of any legal deficiencies under the laws of the requesting party or any relevant conflicts with applicable law of the European Union or applicable Member State law.

If, after the steps described in a. through c. above, Microsoft or any of its affiliates remains compelled to disclose personal data, Microsoft will disclose only the minimum amount of that data necessary to satisfy the order for compelled disclosure.

For purpose of this section, lawful efforts do not include actions that would result in civil or criminal penalty such as contempt of court under the laws of the relevant jurisdiction.

2. **Indemnification of Data Subjects.** Subject to Sections 3 and 4, Microsoft shall indemnify a data subject for any material or non-material damage to the data subject caused by

Source: [Data Protection Addendum \(DPA\) – chapter “Appendix C – Additional Safeguards Addendum”](#)

General Terms

Compliance with Laws

Microsoft will comply with all laws and regulations applicable to its providing the Products and Services, including security breach notification law and Data Protection Requirements. However, Microsoft is not responsible for compliance with any laws or regulations applicable to Customer or Customer’s industry that are not generally applicable to information technology service providers. Microsoft does not determine whether Customer’s data includes information subject to any specific law or regulation. All Security Incidents are subject to the Security Incident Notification terms below.

Customer must comply with all laws and regulations applicable to its use of Products and Services, including laws related to biometric data, confidentiality of communications, and Data Protection Requirements. Customer is responsible for determining whether the Products and Services are appropriate for storage and processing of information subject to any specific law or regulation and for using the Products and Services in a manner consistent with Customer’s legal and regulatory obligations. Customer is responsible for responding to any request from a third party regarding Customer’s use of Products and Services, such as a request to take down content under the U.S. Digital Millennium Copyright Act or other applicable laws.

Source: [Data Protection Addendum \(DPA\) – chapter “General Terms”](#)

auf die Schweiz. Das schweizerische Datenschutzrecht wurde zudem soeben totalrevidiert. Im vorliegenden Bericht wird die Vereinbarkeit des CLOUD Acts mit dem geltenden und dem künftigen Datenschutzrecht analysiert. Das Ergebnis dieser Analyse legt den Schluss nahe, dass eine Herausgabe von Daten gestützt auf eine Herausgabeanordnung auf der Grundlage des CLOUD Acts nur in spezifischen Ausnahmefällen mit dem schweizerischen und europäischen Datenschutzrecht vereinbar ist.

Source: [Gutachten des Bundesamts für Justiz - Bericht zum US CLOUD Act](#)



Encryption



Data Protection Addendum (DPA) - Encryption

Data Encryption

Customer Data and Professional Services Data (each including any Personal Data therein) in transit over public networks between Customer and Microsoft, or between Microsoft data centers, is encrypted by default.

Microsoft also encrypts Customer Data stored at rest in Online Services and Professional Services Data stored at rest. In the case of Online Services on which Customer or a third-party acting on Customer's behalf may build applications (e.g., certain Azure Services), encryption of data stored in such applications may be employed at the discretion of Customer, using either capabilities provided by Microsoft or obtained by Customer from third parties.

Types of Encryption Keys

Microsoft Managed Keys

Microsoft manages cloud keys on customers behalf; easiest to set up, but still highly secure, suitable for most small and medium organizations.

There is no impact on our services and all functions work as expected.

Bring Your Own Key (BYOK)

Customer manages its own cloud keys, but shares access with Microsoft to permit malware scanning, indexing, compliance (e.g., eDiscovery), emergency recovery; more expensive, requires more customer tech skills, but can aid compliance with data protection laws (e.g., GDPR, HIPAA).

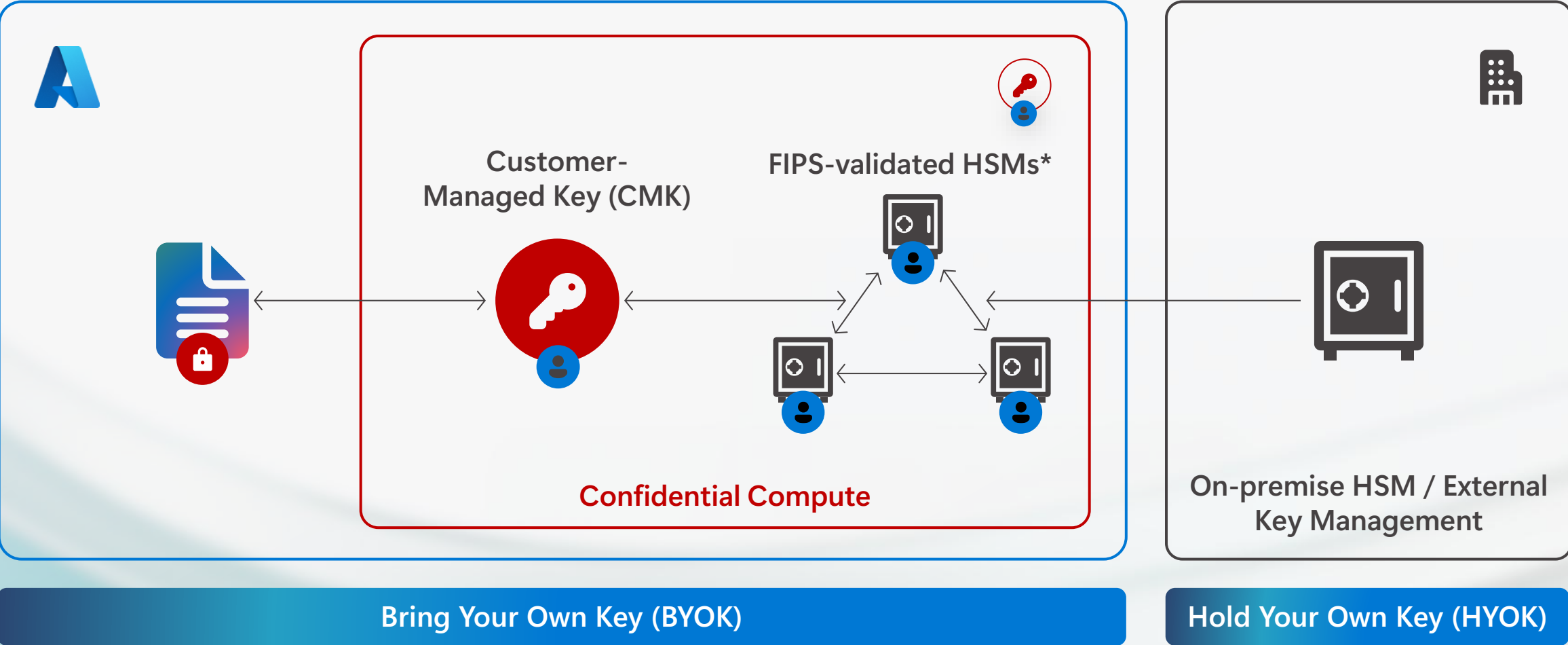
There is no impact on our services and all functions work as expected.

Hold Your Own Key (HYOK)

Customer retains exclusive control on its own premises of keys used for top secret subset of its information (1% or 2%), while continuing to use cloud keys for other sensitive information; imposes extra cost and extra risk (because blocks cloud scanning for malware and compliance), but may be required by some customers.

There is an impact on the services, as data no longer readable (accessible)!

Encryption with Customer controlled Keys (BYOK)

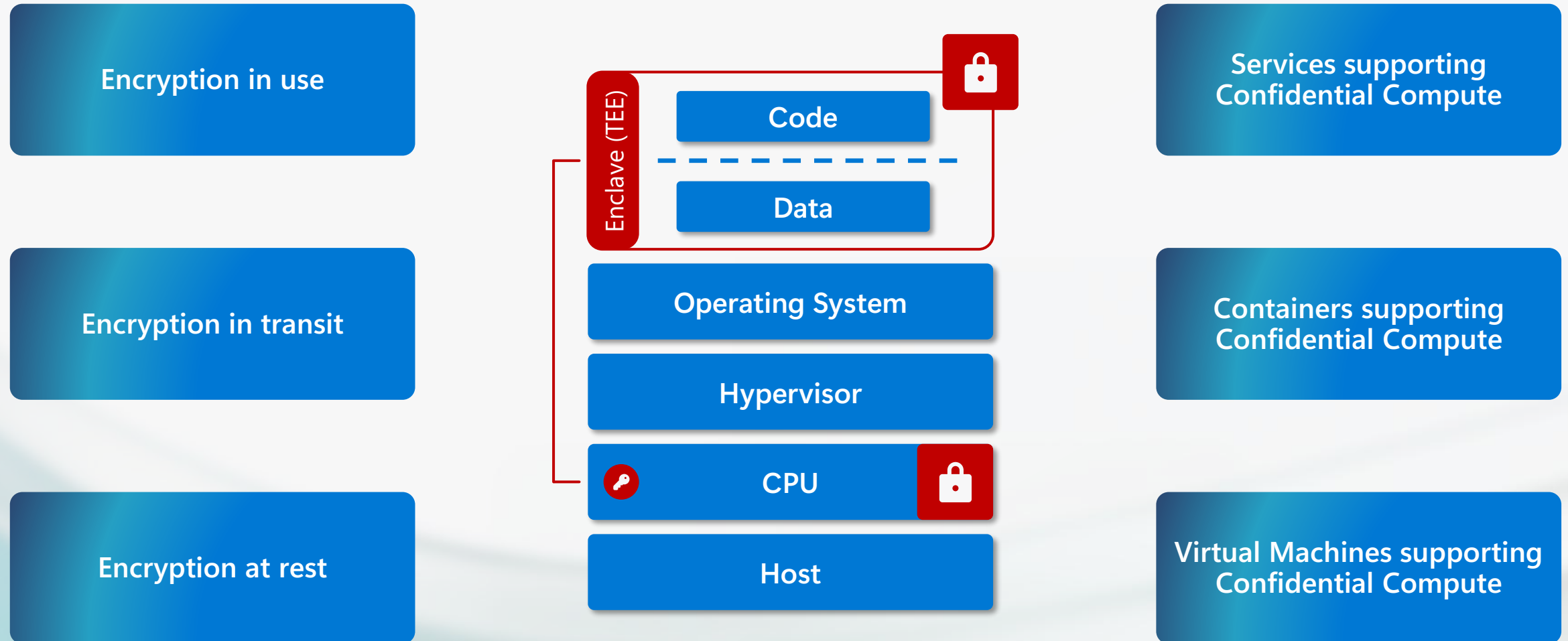


*FIPS 140-3 level 3

Encryption with Customer Managed Key Options

	AKV Standard	AKV Premium	Azure Managed HSM	Azure Cloud HSM	Azure Payment HSM
What level of compliance do you need?	FIPS 140-2 level 1	FIPS 140-3 level 3, PCI DSS, PCI 3DS	FIPS 140-3 level 3, PCI DSS, PCI 3DS	FIPS 140-3 level 3, HIPAA, PCI DSS, PCI 3DS, eIDAS	FIPS 140-2 level 3, PCI HSM v3, PCI PTS HSM v3, PCI DSS, PCI 3DS, PCI PIN
Do you need key sovereignty ?	No	No	Yes	Yes	Yes
What kind of tenancy are you looking for?	Multitenant	Multitenant	Single Tenant	Single Tenant	Single Tenant
What are your use cases ?	Encryption at Rest, CMK, custom	Encryption at Rest, CMK, custom	Encryption at Rest, TLS Offload, CMK, custom	PKCS11, TLS Offload, code/document signing, custom	Payment PIN processes, custom
Do you want HSM hardware protection ?	No	Yes	Yes	Yes	Yes
What is your budget ?	\$	\$\$	\$\$\$	\$\$\$	\$\$\$\$
Who takes responsibility for patching and maintenance ?	Microsoft	Microsoft	Microsoft	Microsoft	Customer
Who takes responsibility for service health and hardware failover ?	Microsoft	Microsoft	Shared	Shared	Customer
What kind of objects are you using?	Asym Keys, Secrets, Certs	Asym Keys, Secrets, Certs	Asym/Sym Keys	Asym/Sym Keys, Certs	Local Master Key
Root of trust control	Microsoft	Microsoft	Customer	Customer	Customer

Confidential Compute



Lock-in concerns / Exit strategy

Data portability

The **EU Data Act** creates new obligations for cloud services to support data access and exportability to reduce vendor lock-in and facilitate interoperability for scenarios such as switching and multi-cloud use.

[Exporting Customer Data and Enabling Cloud Choice - Microsoft Service Assurance | Microsoft Learn](#)

Exit Planning

[Strengthening operational resilience and reducing concentration risk in financial services - Microsoft Service Assurance | Microsoft Learn](#)



Open Exchange

Thank You!

Daniel von Büren

✉ danvo@microsoft.com

☎ +41 78 844 68 37



<https://www.linkedin.com/in/dvonbueren/>

